

VAPT LAB METASPLOITABLE

Metasploitable 2 — Vulnerability Assessment & Penetration Testing Report

Report Type	Vulnerability Assessment & Penetration Testing (VAPT)
Target System	Metasploitable 2 (192.168.56.102)
Attacker System	Kali Linux (192.168.56.101)
Test Environment	Isolated VirtualBox Lab — Windows 11 Host
Test Date	May 23, 2026
Authored by	Yashkumar Parmar

⚠ DISCLAIMER

All tests were performed in a fully isolated, controlled lab environment on intentionally vulnerable machines.

Table of Contents

1. Executive Summary	3
2. Scope & Objectives	4
3. Lab Environment & Methodology	5
4. Phase 1: Reconnaissance — Wireshark & Nmap	7
5. Phase 2: Web Server Scanning — Nikto	10
6. Phase 3: Vulnerability Assessment — Nessus	12
7. Phase 4: Penetration Testing — Burp Suite (DVWA)	14
8. Phase 5: Telnet Exploitation	17
9. Phase 6: FTP Anonymous Login (VSFTPd 2.3.4)	18
10. Phase 7: SMB Enumeration (SMBClient)	19
11. Consolidated Findings & Risk Matrix	20
12. Remediation Recommendations	21
13. Conclusion	23

1. Executive Summary

This report documents the results of a Vulnerability Assessment and Penetration Testing (VAPT) exercise conducted on a Metasploitable 2 virtual machine. The assessment was performed from a Kali Linux attacker machine within an isolated VirtualBox lab environment hosted on a Windows 11 laptop.

The primary objective was to simulate a real-world attack lifecycle — from initial reconnaissance and scanning through to active exploitation — using industry-standard offensive security tools. The assessment identified a significant number of critical and high-severity vulnerabilities across multiple services.

Key Findings Summary

Critical	High	Medium	Low	Info	Total Vulnerabilities
5	3	4	3	Various	69 Total (Nessus)

Successful exploitation was demonstrated across multiple attack vectors including anonymous FTP login, Telnet default credential access, web application command injection via DVWA, and SMB share enumeration. The target system was found to be critically vulnerable across virtually all exposed services, consistent with its design as a deliberately vulnerable training platform.

2. Scope & Objectives

2.1 Scope of Assessment

Target IP	192.168.56.102 (Metasploitable 2)
Attacker IP	192.168.56.101 (Kali Linux)
Network	VirtualBox Host-Only Network (192.168.56.0/24)
Ports in Scope	All open ports (30+ identified)
Services in Scope	FTP, SSH, Telnet, HTTP, SMB, VNC, MySQL, PostgreSQL, and others
Out of Scope	Host machine (Windows 11), external internet

2.2 Objectives

- Identify open ports and running services on the target
- Enumerate web application vulnerabilities using active scanning tools
- Perform a comprehensive automated vulnerability scan using Nessus
- Exploit identified vulnerabilities to demonstrate real-world risk
- Document all findings with evidence and provide remediation guidance

3. Lab Environment & Methodology

3.1 Environment Overview

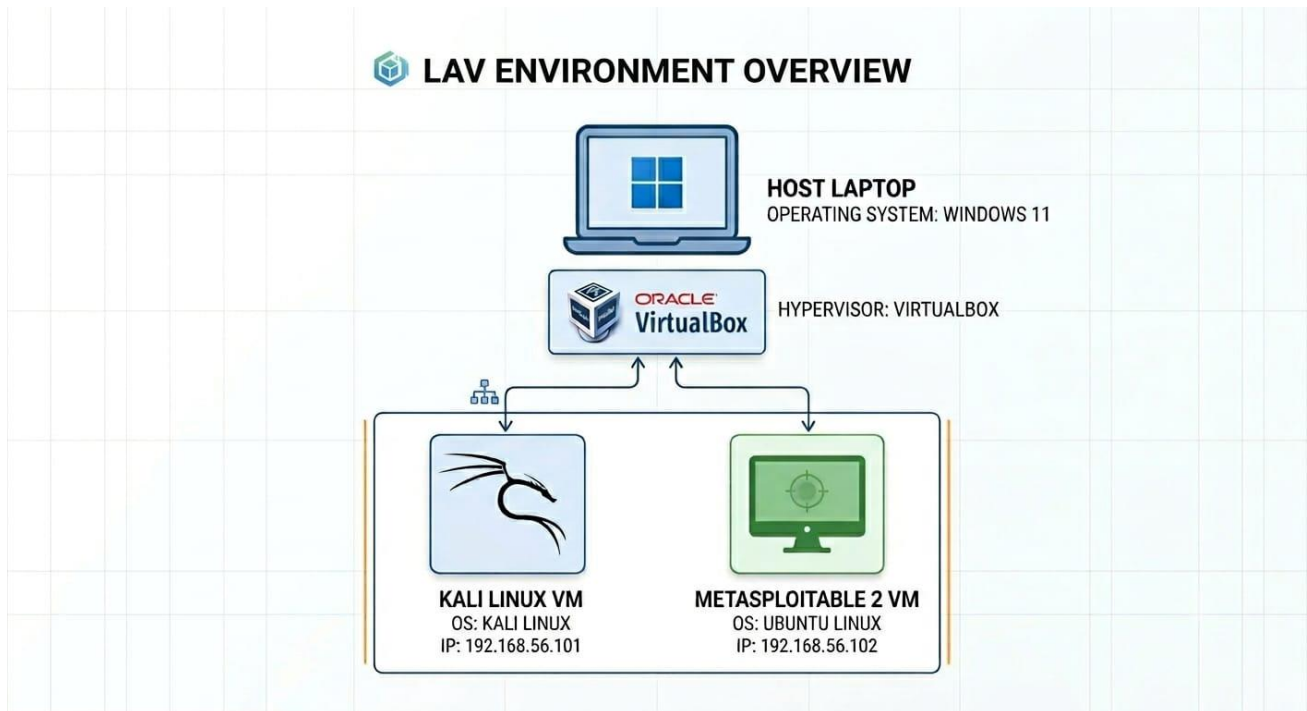


Figure 1: Lab Environment Architecture — Windows 11 Host running Kali Linux and Metasploitable 2 via VirtualBox

3.2 Network Configuration

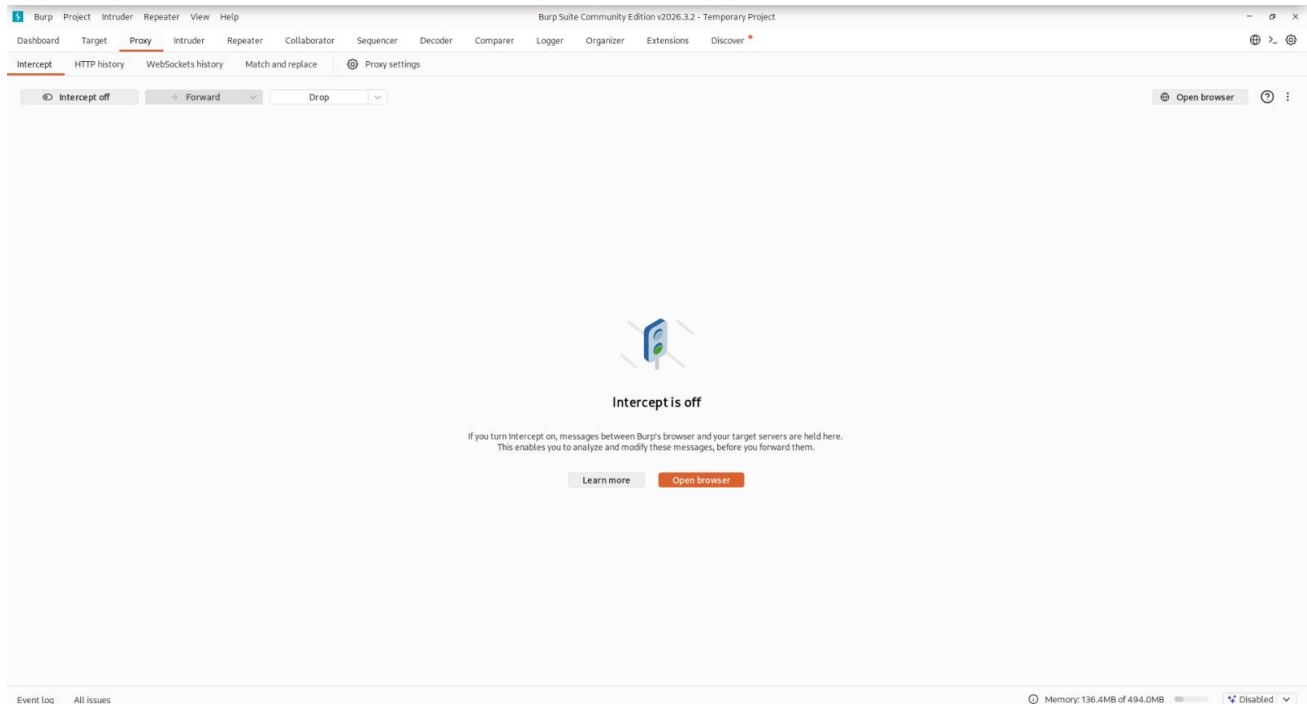
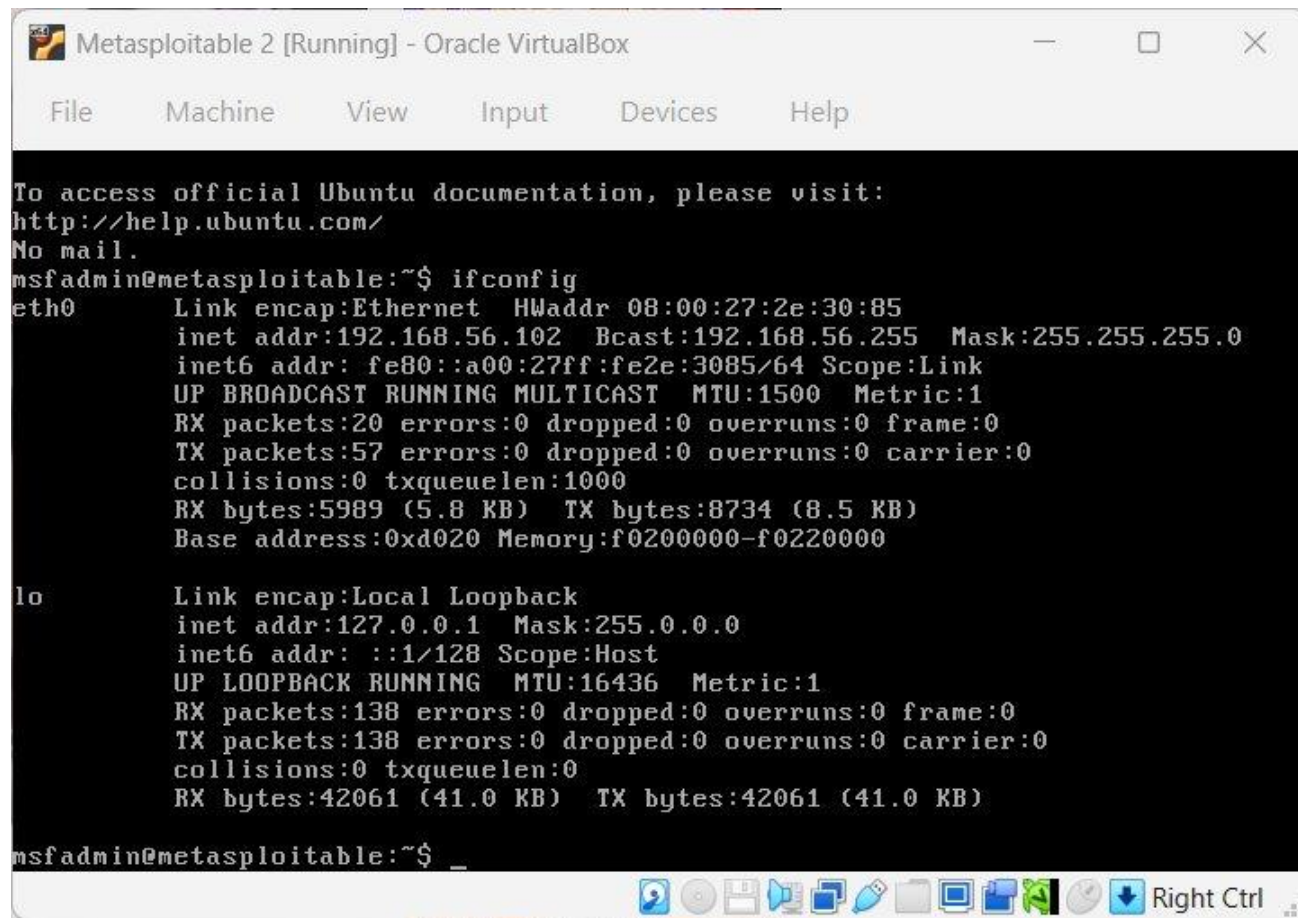


Figure 2: Kali Linux IP Configuration (192.168.56.101) and successful ping to Metasploitable 2 (192.168.56.102)



The screenshot shows a terminal window titled "Metasploitable 2 [Running] - Oracle VirtualBox". The terminal displays the output of the `ifconfig` command. It shows details for the `eth0` interface, including its IP address (`192.168.56.102`), broadcast address (`192.168.56.255`), and mask (`255.255.255.0`). It also shows details for the `lo` (loopback) interface with IP `127.0.0.1`. The prompt is `msfadmin@metasploitable:~$`.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:2e:30:85
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe2e:3085/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:20 errors:0 dropped:0 overruns:0 frame:0
          TX packets:57 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5989 (5.8 KB)  TX bytes:8734 (8.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:138 errors:0 dropped:0 overruns:0 frame:0
          TX packets:138 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:42061 (41.0 KB)  TX bytes:42061 (41.0 KB)

msfadmin@metasploitable:~$
```

Figure 3: Metasploitable 2 `ifconfig` — confirming target IP 192.168.56.102

3.3 VAPT Methodology

This assessment followed the standard VAPT lifecycle across seven sequential phases:

1. Phase 1 — Reconnaissance: Wireshark passive capture and Nmap active port scan
2. Phase 2 — Web Server Scanning: Nikto scan against HTTP service on port 80
3. Phase 3 — Vulnerability Assessment: Nessus Essentials automated scan of all services
4. Phase 4 — Web Application Exploitation: Burp Suite proxy interception against DVWA
5. Phase 5 — Remote Access Exploitation: Telnet login using default credentials
6. Phase 6 — FTP Exploitation: Anonymous login to VSFTPd 2.3.4
7. Phase 7 — SMB Enumeration: SMBClient anonymous share listing

4. Phase 1: Reconnaissance — Wireshark & Nmap

4.1 Wireshark — Passive Network Capture

Wireshark was launched on the Kali Linux machine to capture all network traffic on the eth0 interface prior to and during the attack phases. The capture provided baseline network visibility and confirmed the presence of the target host on the local subnet.

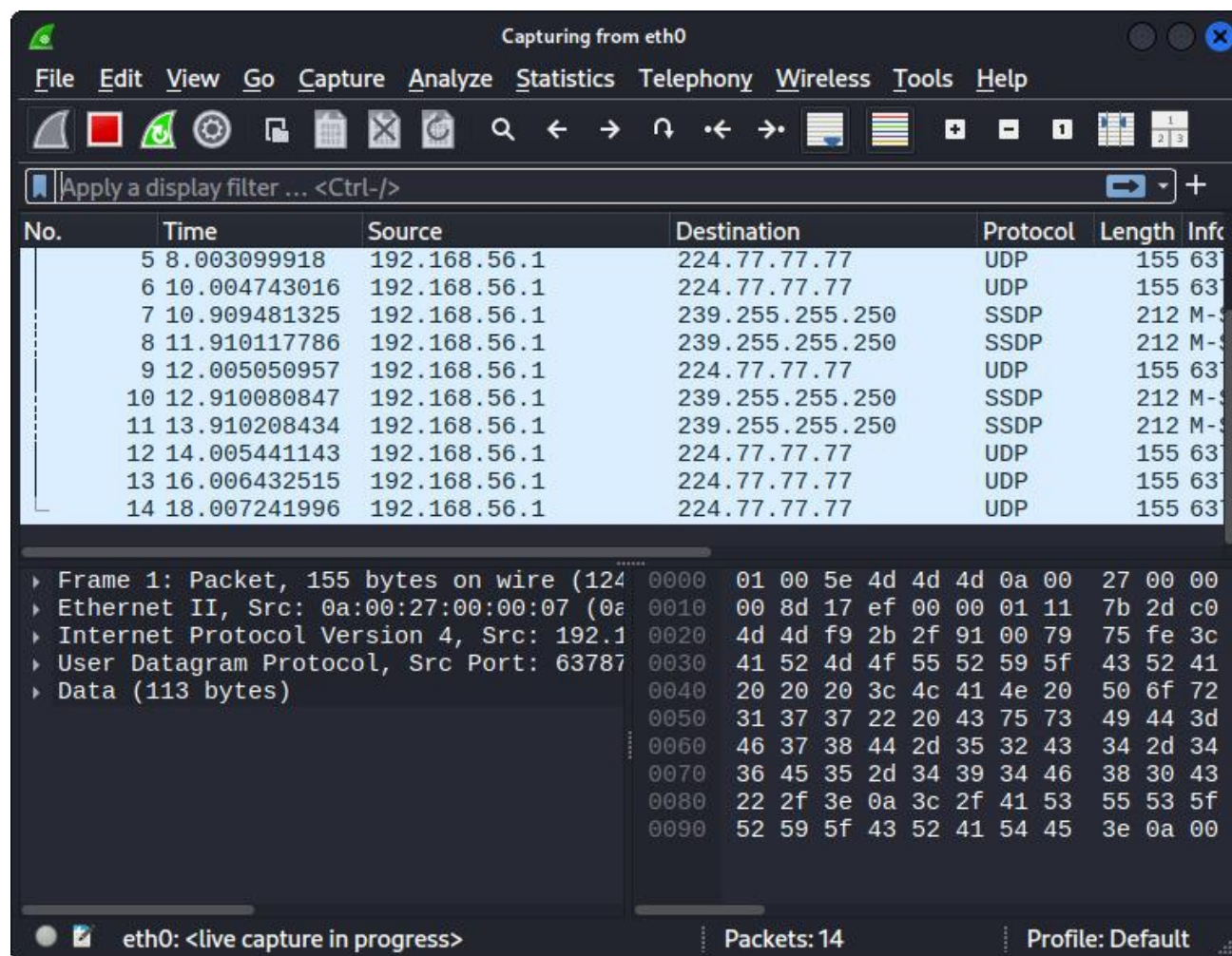


Figure 4: Wireshark live capture on eth0 — initial UDP/SSDP broadcast traffic observed from 192.168.56.1

During subsequent attack phases, Wireshark captured detailed packet-level evidence of all connections made to the target, including TCP handshakes, FTP banners, HTTP requests, and SSH protocol exchanges. The capture confirmed that FTP and Telnet services transmit data in plaintext, a significant security risk.

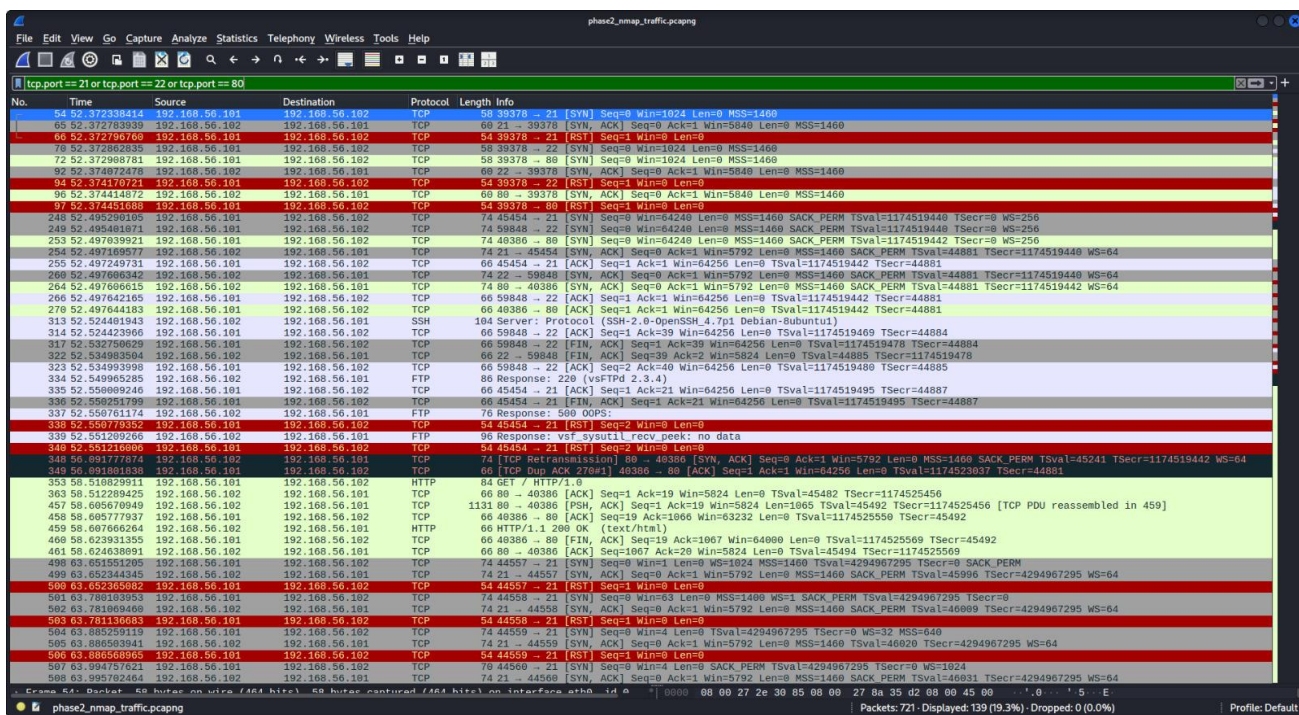


Figure 5: Wireshark filtered view (tcp.port == 21 or 22 or 80) — showing FTP banner (vsFTPd 2.3.4), SSH, HTTP and TCP RST packets confirming active port scanning activity

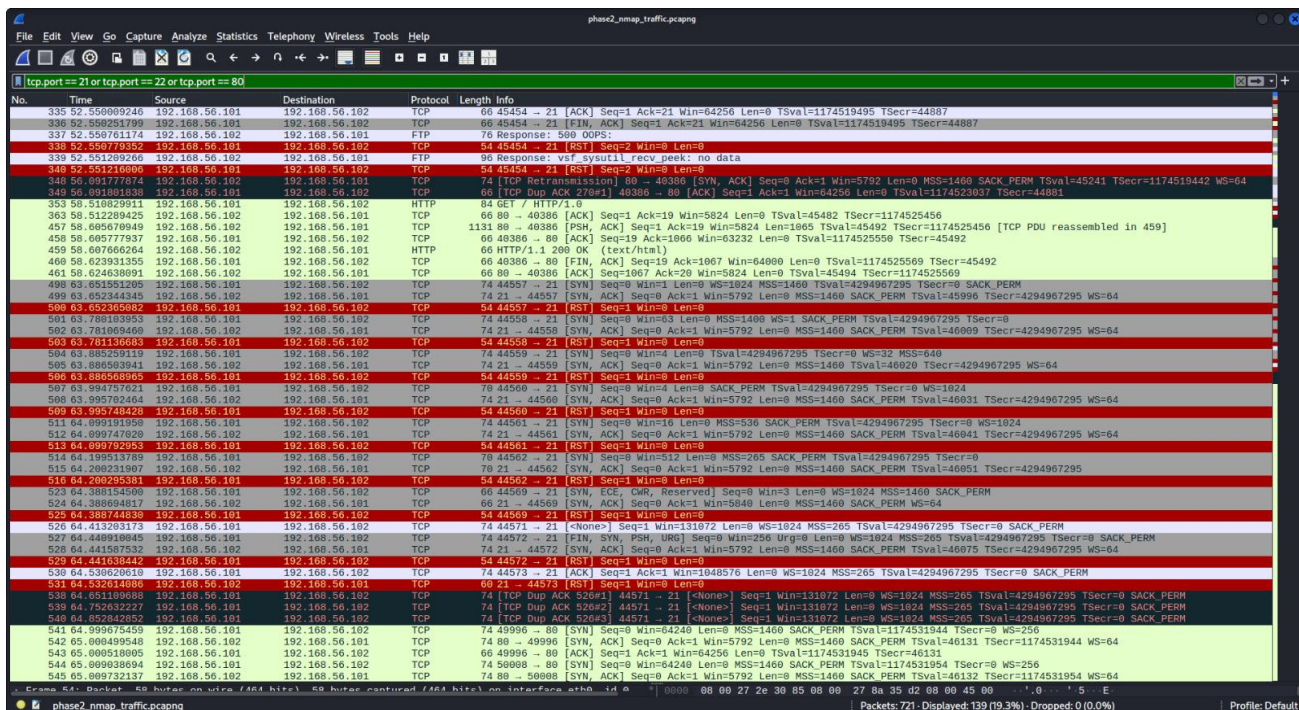


Figure 6: Continued Wireshark capture showing extensive TCP SYN/RST scan traffic and HTTP GET/200 OK responses during the reconnaissance phase

4.2 Nmap — Port & Service Enumeration

An Nmap service version scan was run against the target to enumerate all open TCP ports and identify running service versions. The command used was:

```
nmap -sS -sV -O -p- --min-rate 1000 192.168.56.102 -oN nmap_report.txt
```

The scan revealed over 30 open TCP ports exposing a wide attack surface. Key services identified included:

```

kali@kali:~$ nmap -sS -sV -O -p- --min-rate 1000 192.168.56.102 -oN nmap_report.txt
Starting Nmap 7.90 ( https://nmap.org ) at 2026-05-23 04:44 -0400
Nmap scan report for 192.168.56.102
Host is up (0.00072s latency).
Not shown: 65535 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
52/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        Netkit rshd
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath gmicregistry
1524/tcp  open  bindshell    Metasploitables root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3206/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-3ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6067/tcp  open  irc          UnrealIRCd
6097/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8182/tcp  open  drb          Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
41829/tcp open  status       1 (RPC #100024)
46566/tcp open  java-rmi     GNU Classpath gmicregistry
58062/tcp open  rlocmgr      1-4 (RPC #100021)
58400/tcp open  mountd       1-1 (RPC #100005)
MAC Address: 08:00:27:2E:30:85 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 150.87 seconds
kali@kali:~$

```

Figure 7: Nmap scan results showing 30+ open ports on Metasploitable 2 including FTP (21), SSH (22), Telnet (23), HTTP (80), SMB (139/445), VNC (5900), and many others

4.3 Nmap Findings — Open Ports Summary

Port	State	Service	Version / Notes
21/tcp	Open	FTP	vsFTPD 2.3.4 — contains backdoor (CVE-2011-2523)
22/tcp	Open	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	Open	Telnet	Linux telnetd — unencrypted, default creds accepted
25/tcp	Open	SMTP	Postfix smtpd
80/tcp	Open	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
139/tcp	Open	NetBIOS	Samba smbd 3.X-4.X (WORKGROUP)
445/tcp	Open	SMB	Samba smbd 3.X-4.X — anonymous login enabled
3306/tcp	Open	MySQL	MySQL 5.0.51a-3ubuntu5
5432/tcp	Open	PostgreSQL	PostgreSQL DB 8.3.0-8.3.7
5900/tcp	Open	VNC	VNC protocol 3.3 — password-protected
8009/tcp	Open	AJP13	Apache Jserv (Ghostcat vulnerable)
8180/tcp	Open	HTTP	Apache Tomcat/Coyote JSP engine 1.1

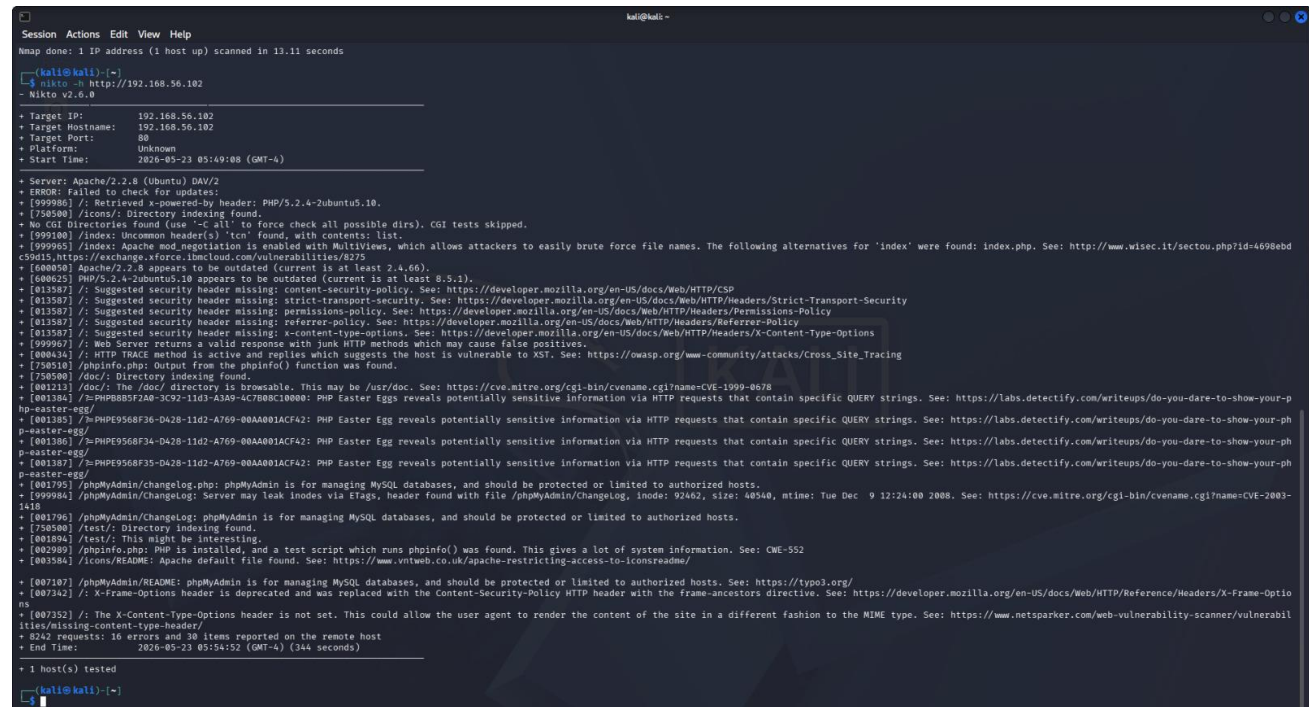
5. Phase 2: Web Server Scanning — Nikto

Nikto v2.6.0 was used to perform an automated web server vulnerability scan against the HTTP service running on port 80 of the target. Nikto performs comprehensive checks for known web server misconfigurations, outdated software, exposed files, and common web vulnerabilities.

Command used:

```
nikto -h http://192.168.56.102
```

The scan completed in 344 seconds, making 8,242 requests and identifying 16 errors and 30 items on the remote host. Key findings included:



```

kali@kali:~$ nikto -h http://192.168.56.102
- Nikto v2.6.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-23 05:49:08 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ BRK008: Failed to check for updates:
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-c all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Incoming headers: 'icon' found, with contents: list.
+ [999955] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebd
+ [500000] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [999997] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000436] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [720510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001304] /phpBB85f2a8-3C92-11d3-A3A9-4C7B0BC10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-p
+ [001385] /phpPE9568f36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-ph
+ [001386] /phpPE9568f34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-ph
+ [001387] /phpPE9568f35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-ph
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999981] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001836] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-icons/readme/

+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Optio
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabil
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabil
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-05-23 05:54:52 (GMT-4) (344 seconds)

+ 1 host(s) tested

```

Figure 8: Nikto v2.6.0 scan output against 192.168.56.102:80 — 30 security issues identified including outdated Apache, PHP Easter Eggs, missing security headers, and exposed phpMyAdmin

5.1 Nikto Key Findings

Severity	Finding	Detail
HIGH	Outdated Apache Web Server	Apache 2.2.8 detected; current is 2.4.66+
HIGH	Outdated PHP Version	PHP 5.2.4 detected; current is 8.5+
HIGH	HTTP TRACE Method Enabled	Vulnerable to Cross-Site Tracing (XST)
HIGH	PHP Easter Eggs Exposed	Reveals sensitive version info via query strings
MEDIUM	Missing Content-Security-Policy	CSP header absent — XSS risk elevated
MEDIUM	Missing Strict-Transport-Security	HSTS header absent
MEDIUM	Missing X-Content-Type-Options	MIME sniffing attacks possible
MEDIUM	phpMyAdmin Exposed	phpMyAdmin accessible without IP restriction
MEDIUM	Directory Indexing Enabled	/icons/, /doc/, /test/ directories browsable
LOW	phpinfo.php Present	Leaks full server configuration details
LOW	Apache README Exposed	Default file found — information disclosure
INFO	Uncommon Header tcn	Content negotiation header indicates mod_negotiation

Nessus Essentials v10.12.0 was installed on the Kali Linux machine and configured to perform a Basic Network Scan against the Metasploitable 2 target (192.168.56.102). The scan was named "Metasploitable Assessment" and completed in 12 minutes, identifying a total of 69 vulnerabilities across all exposed services.

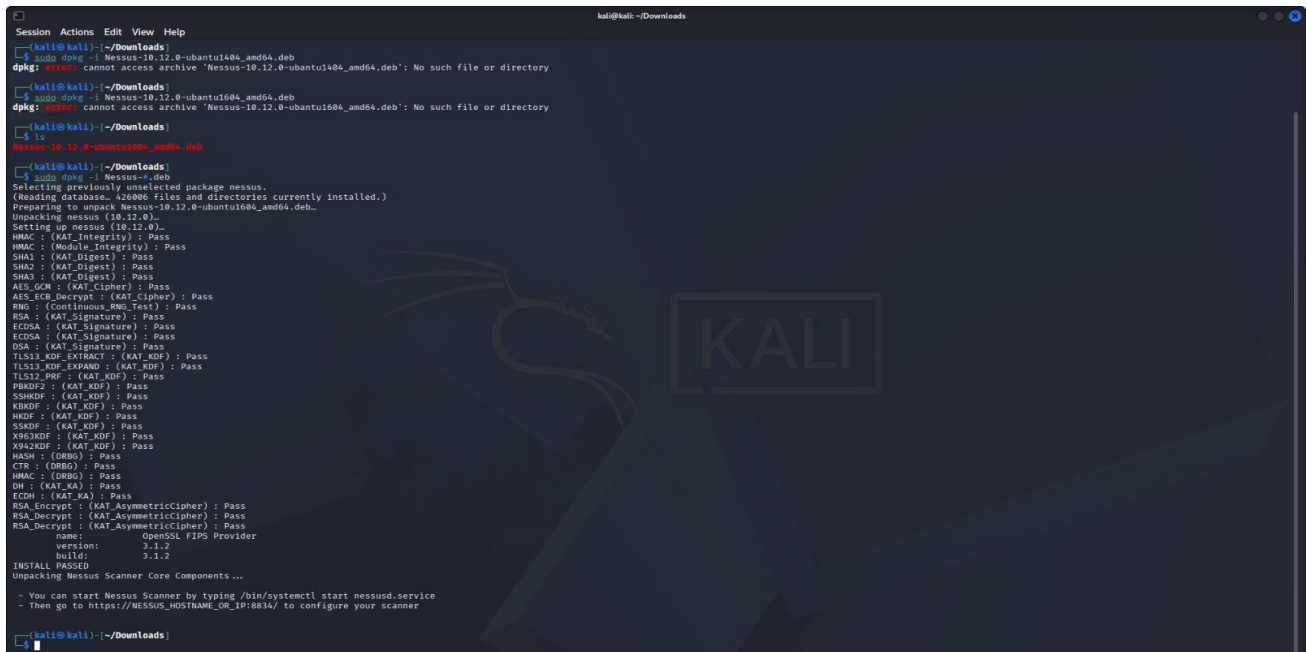


Figure 9: Nessus installation on Kali Linux — all cryptographic integrity checks passed (HMAC, SHA, AES, RSA)

6.1 Nessus Scan Results — Critical & High Findings

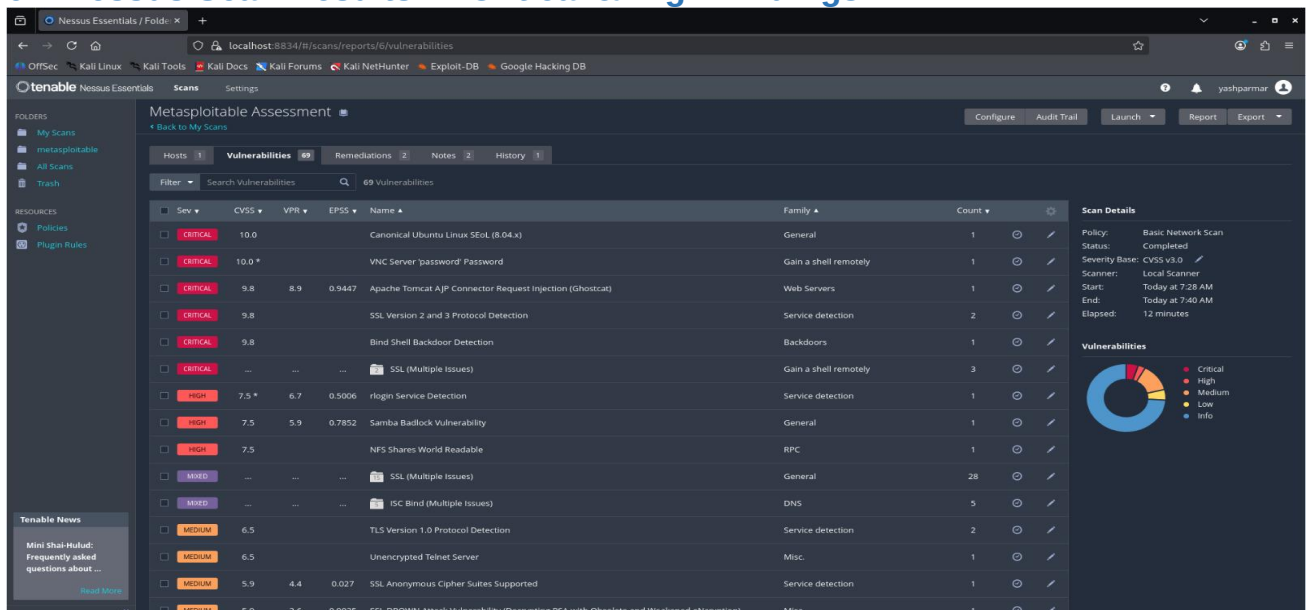


Figure 10: Nessus Essentials "Metasploitable Assessment" results — 69 vulnerabilities identified. Critical findings include Ubuntu Linux SEoL (CVSS 10.0), VNC password vulnerability (CVSS 10.0), and Apache Tomcat Ghostcat (CVSS 9.8)

6.2 Nessus Scan Results — Medium & Lower Findings

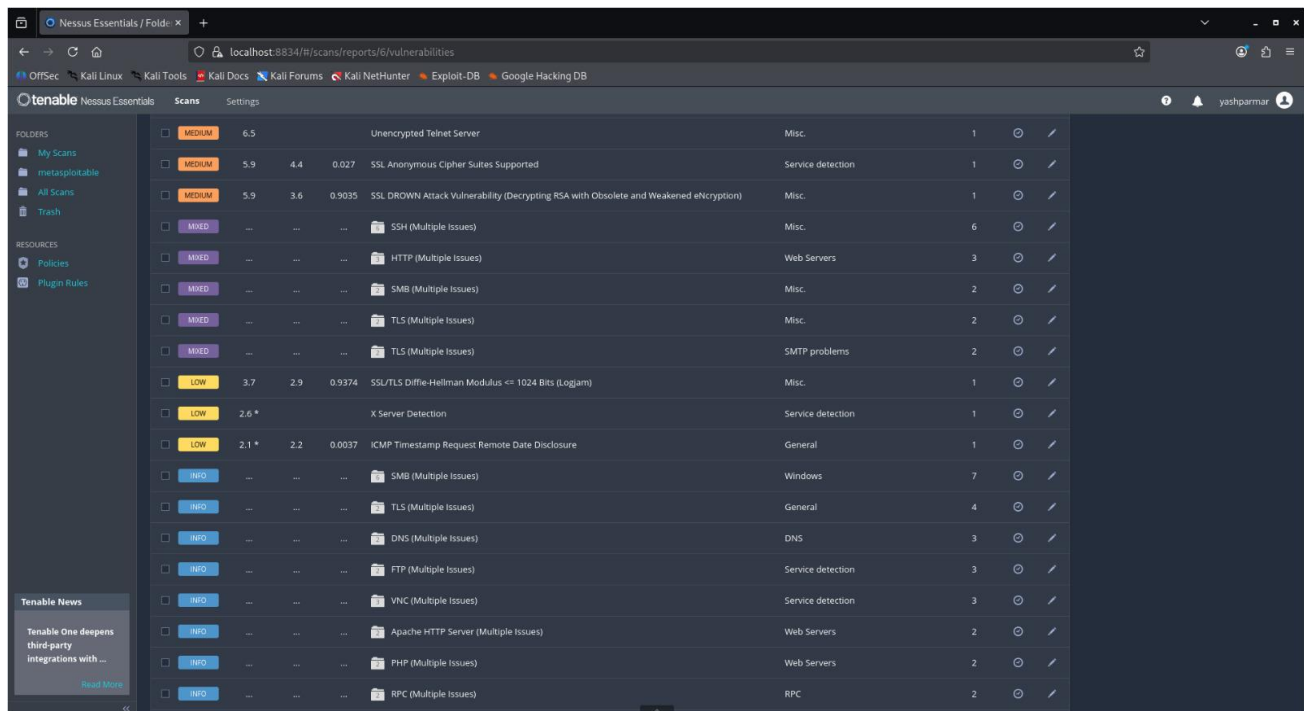


Figure 11: Continued Nessus results showing Medium severity findings including Unencrypted Telnet Server, SSL DROWN vulnerability, and multiple SSH/HTTP/SMB/TLS mixed-severity issues

6.3 Critical & High Vulnerability Detail

Severity	CVSS	Vulnerability	Family
CRITICAL	10.0	Canonical Ubuntu Linux SEoL (8.04.x)	General
CRITICAL	10.0	VNC Server Password Authentication Bypass	Gain shell remotely
CRITICAL	9.8	Apache Tomcat AJP Ghostcat (CVE-2020-1938)	Web Servers
CRITICAL	9.8	SSL Version 2 and 3 Protocol Detection	Service Detection
CRITICAL	9.8	Bind Shell Backdoor Detection	Backdoors
CRITICAL	N/A	SSL Multiple Issues	Gain shell remotely
HIGH	7.5	rlogin Service Detection	Service Detection
HIGH	7.5	Samba Badlock Vulnerability	General
HIGH	7.5	NFS Shares World Readable	RPC
MEDIUM	6.5	TLS Version 1.0 Protocol Detection	Service Detection
MEDIUM	6.5	Unencrypted Telnet Server	Misc
MEDIUM	5.9	SSL Anonymous Cipher Suites Supported	Service Detection
MEDIUM	5.9	SSL DROWN Attack Vulnerability	Misc
LOW	3.7	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits	Misc
LOW	2.6	X Server Detection	Service Detection

7. Phase 4: Web Application Testing — Burp Suite

Burp Suite Community Edition v2026.3.2 was configured as an HTTP proxy (listening on 127.0.0.1:8080) to intercept all HTTP traffic between the Kali Linux browser and the Metasploitable 2 web server. The primary target was the Damn Vulnerable Web Application (DVWA) running at <http://192.168.56.102/dvwa>.

7.1 Burp Suite Proxy Setup & HTTP History

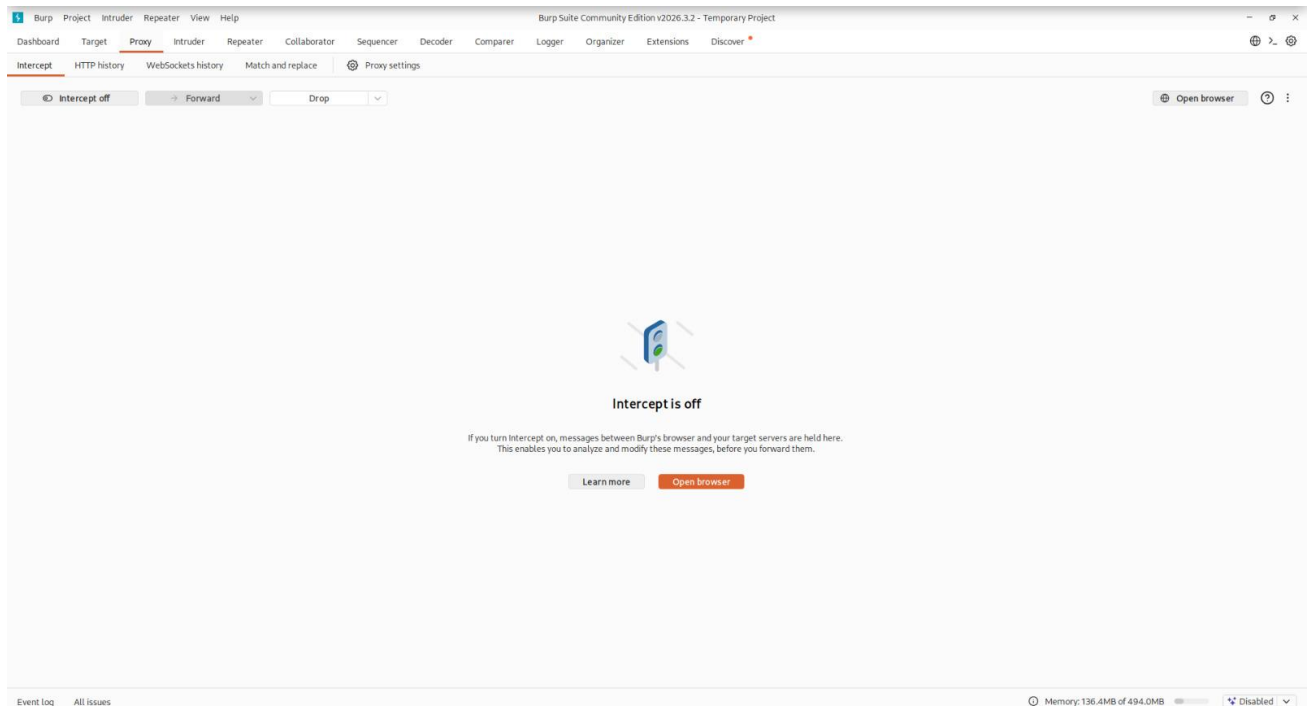


Figure 12: Burp Suite Proxy — Intercept tab in standby mode, configured to intercept traffic to 192.168.56.102:80

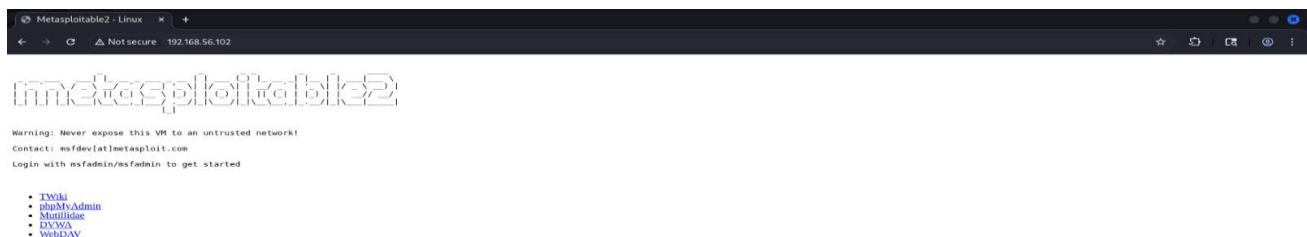


Figure 13: Burp Suite HTTP History — complete request log showing DVWA login, security configuration, and command execution endpoint interactions. POST requests with modified parameters are clearly marked (checkmark in Edited column)

7.2 HTTP Request/Response Analysis

Burp Suite's request inspector revealed critical information about the target web server. The response headers confirmed Apache 2.2.8 running on Ubuntu with PHP 5.2.4, both significantly outdated versions with known CVEs.

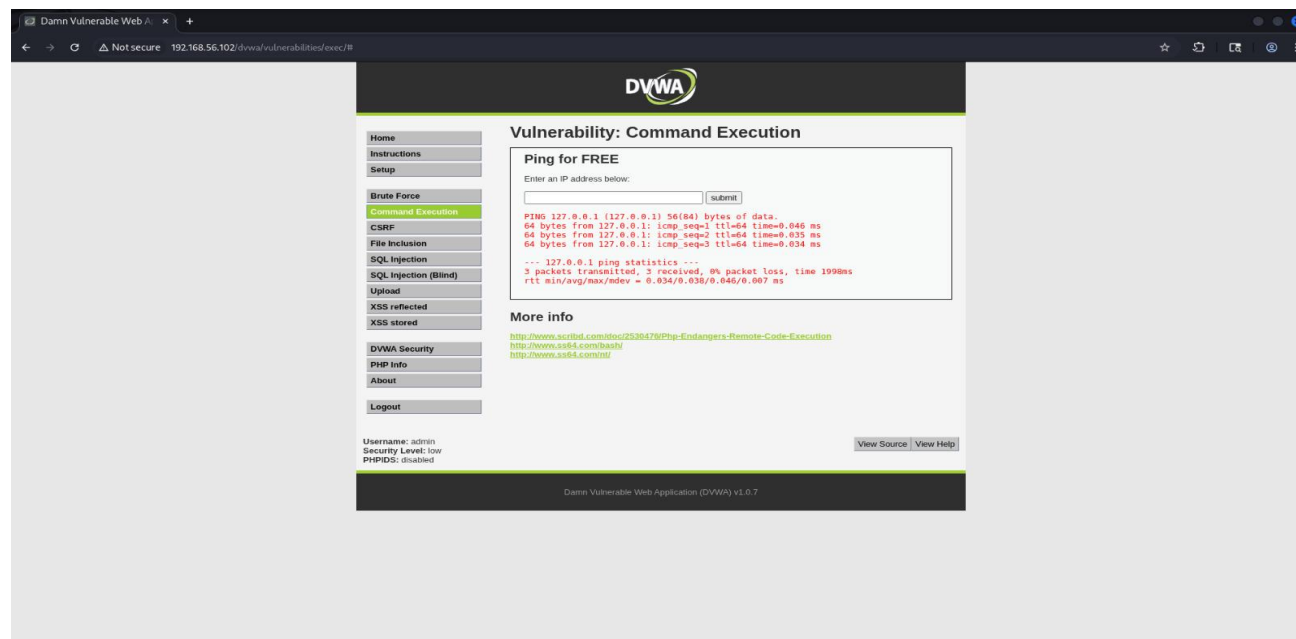


Figure 14: Burp Suite request/response pair for GET / — server response headers confirm Apache/2.2.8 (Ubuntu) DAV/2 and PHP/5.2.4-2ubuntu5.10, both critically outdated

7.3 DVWA Command Execution Vulnerability

The DVWA Command Execution module (at /dwa/vulnerabilities/exec/) was identified as vulnerable to OS command injection. The input field, designed to accept an IP address for ping, accepted arbitrary commands. Burp Suite was used to intercept and inspect the POST request.

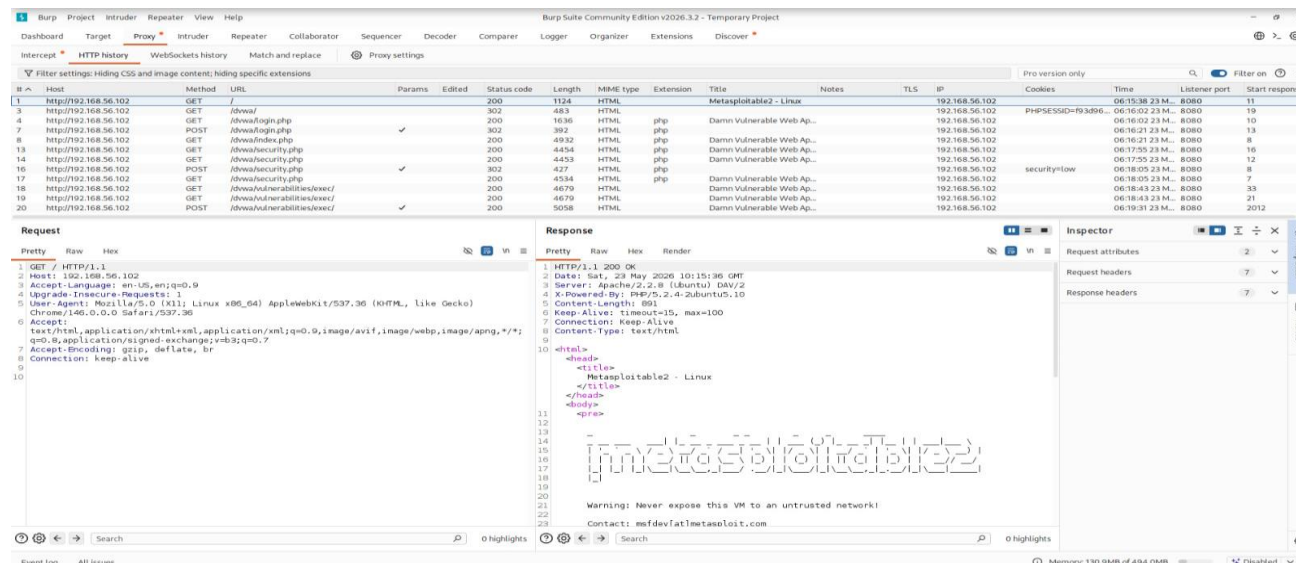


Figure 15: DVWA Command Execution module — successful ping to 127.0.0.1 confirming the input field executes system commands directly

7.4 Burp Suite Intercept — POST Request Capture

Using Burp Suite's Intercept feature, a POST request to the command execution endpoint was captured mid-flight. The intercepted request clearly shows the ip parameter being sent with the value 127.0.0.1, which can be trivially modified to inject arbitrary OS commands (e.g., 127.0.0.1; cat /etc/passwd).

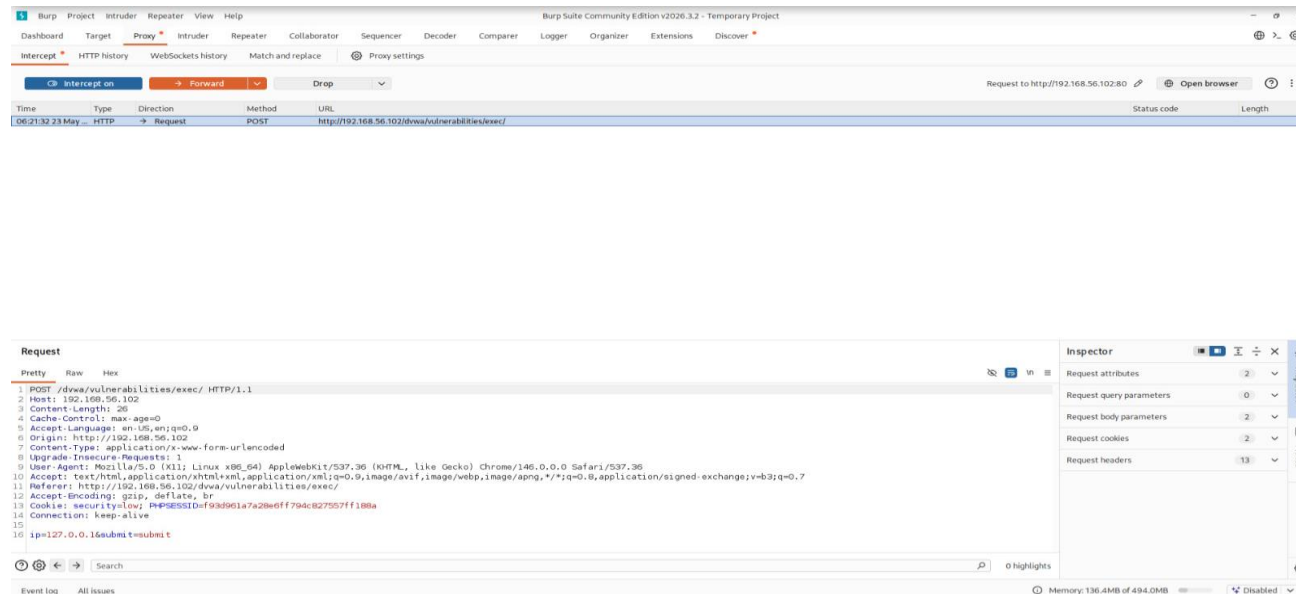


Figure 16: Burp Suite Intercept capturing POST to /dwa/vulnerabilities/exec/ — ip=127.0.0.1&submit=submit. Session cookie (PHPSESSID) and security=low cookie visible, confirming low security mode

The security level of DVWA was set to "low" (confirmed by the security=low cookie), representing systems where developers have not implemented any input sanitisation. This type of vulnerability allows an attacker to execute any command on the server with the privileges of the web server process.

7.5 Additional Burp Suite Captures

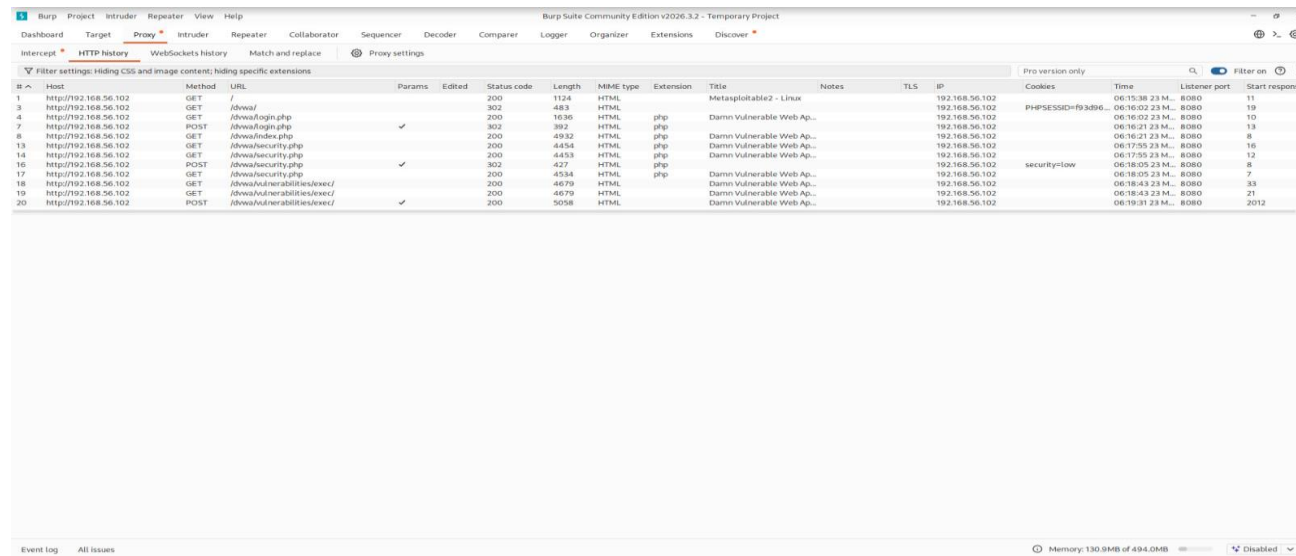


Figure 17: Burp Suite HTTP History — detailed view of multiple DVWA interactions including login POST requests and repeated GET/POST to the command execution endpoint

8. Phase 5: Telnet Exploitation

Telnet (port 23) was identified as running on the target during the Nmap scan phase. Nessus also flagged "Unencrypted Telnet Server" as a Medium severity finding. Telnet transmits all data, including usernames and passwords, in plaintext over the network, making it trivially interceptable with a packet sniffer such as Wireshark.

8.1 Telnet Login — Default Credentials

A Telnet connection was initiated from Kali Linux to the Metasploitable 2 target using the default credentials (msfadmin:msfadmin) that were publicly displayed on the target's web homepage. This represents a critical misconfiguration: default credentials were never changed, and the service was left running without restriction.

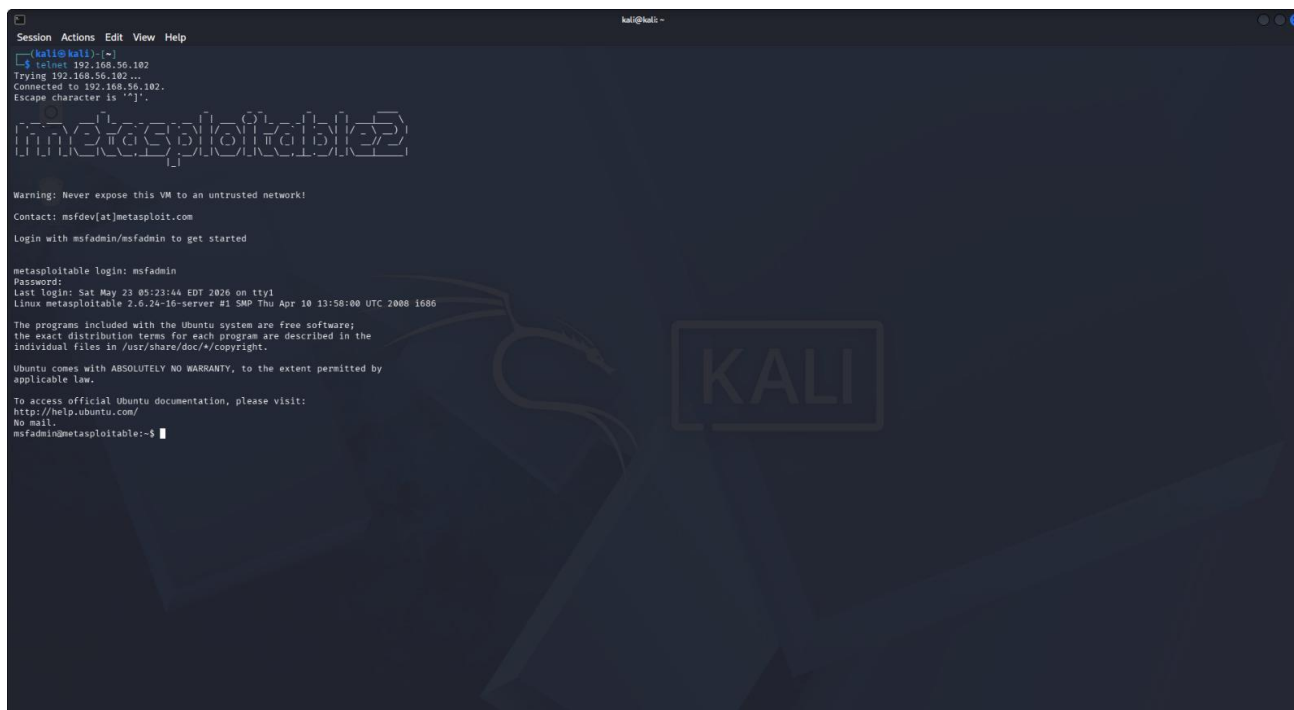


Figure 18: Successful Telnet login to 192.168.56.102 using default credentials msfadmin/msfadmin — full shell access obtained as msfadmin@metasploitable

8.2 Finding Analysis

Attack Vector	Network (remote)
Credentials Used	msfadmin / msfadmin (default, publicly disclosed)
Access Obtained	Interactive shell as msfadmin on target system
Protocol Risk	Plaintext transmission — all data interceptable via Wireshark
CVSS Score	6.5 (Medium) — elevated to High in context of full access
Nessus Finding	Unencrypted Telnet Server (MEDIUM — CVSS 6.5)

9. Phase 6: FTP Anonymous Login — VSFTPD 2.3.4

The FTP service running on port 21 was identified during the Nmap scan as VSFTPD version 2.3.4. This version is infamous for containing a backdoor (CVE-2011-2523) that was introduced into the source code by an attacker in 2011. Additionally, the FTP service was found to accept anonymous logins, a separate misconfiguration that allows unauthenticated file access.

9.1 Anonymous FTP Login



```
Session Actions Edit View Help
kali@kali:~$ ftp 192.168.56.102
Connected to 192.168.56.102.
220 (vsftpd 2.3.4)
Name (192.168.56.102:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Figure 19: Successful anonymous FTP login to VSFTPD 2.3.4 on 192.168.56.102 — "230 Login successful" confirms unauthenticated access to the FTP service

9.2 Finding Analysis

Service	FTP — VSFTPD 2.3.4
Port	21/tcp
CVE	CVE-2011-2523 (VSFTPD 2.3.4 Backdoor) — CVSS 10.0
Anonymous Login	Enabled — no credentials required
Attack Method	Standard FTP client connection as "anonymous" user
Result	"230 Login successful" — full FTP access granted
Additional Risk	VSFTPD 2.3.4 backdoor allows root shell via Metasploit module exploit/unix/ftp/vsftpd_234_backdoor

10. Phase 7: SMB Enumeration — SMBClient

The Samba service running on ports 139 and 445 was identified during the Nmap scan. SMBClient was used to enumerate available network shares on the target using anonymous (unauthenticated) access. This technique is used to identify accessible file shares that could be used for lateral movement or data exfiltration in a real engagement.

10.1 SMBClient Anonymous Share Enumeration

Command used:

```
smbclient -L //192.168.56.102 -N
```

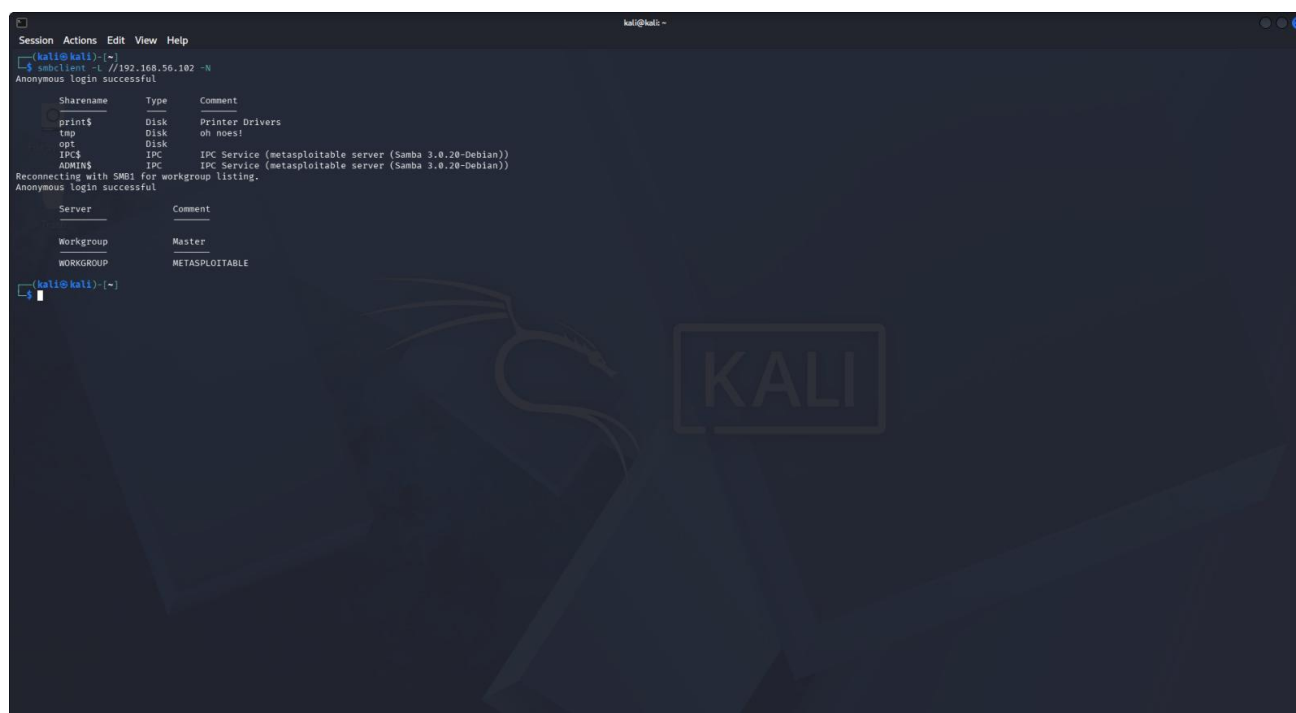


Figure 20: SMBClient anonymous enumeration — "Anonymous login successful" with shares print\$, tmp, opt, IPC\$, and ADMIN\$ listed. Workgroup: WORKGROUP, Master: METASPLOITABLE

10.2 Shares Identified

Share Name	Type	Notes
print\$	Disk	Printer driver share — potentially accessible
tmp	Disk	Temporary files share — read/write access possible
opt	Disk	Optional software share — information disclosure risk
IPC\$	IPC	Inter-Process Communication — metasploitable server
ADMIN\$	IPC	Administrative share — metasploitable server

The tmp share being world-accessible is a notable risk, as it could be used to upload malicious files to the target system. The Samba version (3.0.20) is also known to be vulnerable to CVE-2007-2447, which allows command injection via the username parameter.

11. Consolidated Findings & Risk Matrix

11.1 Master Vulnerability Table

Severity	Vulnerability	Service/Port	Tool	Status
CRITICAL	Ubuntu 8.04 End of Life — No security patches	OS-level	Nessus	Confirmed
CRITICAL	VNC Server Weak/Default Password	VNC / 5900	Nessus	Confirmed
CRITICAL	Apache Tomcat Ghostcat (CVE-2020-1938)	HTTP / 8009	Nessus	Confirmed
CRITICAL	SSL v2/v3 Enabled	Multiple	Nessus	Confirmed
CRITICAL	Bind Shell Backdoor Active	Port 1524	Nessus/Nmap	Confirmed
HIGH	VSFTPD 2.3.4 Anonymous Login	FTP / 21	FTP Client	Exploited
HIGH	Telnet Default Credentials (msfadmin/msfadmin)	Telnet / 23	Telnet	Exploited
HIGH	DVWA Command Injection (OS Command Exec)	HTTP / 80	Burp Suite	Exploited
HIGH	SMB Anonymous Share Enumeration	SMB / 445	SMBClient	Exploited
HIGH	Samba Badlock Vulnerability	SMB / 139	Nessus	Confirmed
HIGH	NFS Shares World Readable	NFS / 2049	Nessus	Confirmed
MEDIUM	Unencrypted Telnet (Plaintext Credentials)	Telnet / 23	Wireshark	Confirmed
MEDIUM	Apache 2.2.8 Outdated — Multiple CVEs	HTTP / 80	Nikto	Confirmed
MEDIUM	PHP 5.2.4 Outdated — Multiple CVEs	HTTP / 80	Nikto	Confirmed
MEDIUM	phpMyAdmin Publicly Accessible	HTTP / 80	Nikto	Confirmed
MEDIUM	Directory Indexing Enabled	HTTP / 80	Nikto	Confirmed
MEDIUM	HTTP TRACE Method Enabled (XST)	HTTP / 80	Nikto	Confirmed
LOW	Missing HTTP Security Headers (CSP, HSTS, XFO)	HTTP / 80	Nikto	Confirmed
LOW	SSL/TLS Weak Diffie-Hellman Parameters	Multiple	Nessus	Confirmed
LOW	phpinfo.php Exposed	HTTP / 80	Nikto	Confirmed

12. Remediation Recommendations

The following remediation actions are recommended, ordered by priority based on severity and exploitability:

Critical Priority — Immediate Action Required

Finding	Recommended Remediation
Ubuntu 8.04 End of Life	Upgrade to a supported Ubuntu LTS release (22.04 or 24.04). Apply all available security patches immediately.
VNC Weak Password	Enforce strong, unique passwords for VNC. Consider disabling VNC entirely and using SSH tunnelling with key-based auth instead.
Tomcat Ghostcat (CVE-2020-1938)	Upgrade Apache Tomcat to 9.0.31+/8.5.51+. Disable AJP connector (port 8009) if not required.
SSL v2/v3 Enabled	Disable SSL v2 and SSL v3 on all services. Enforce TLS 1.2 minimum (TLS 1.3 preferred). Update cipher suites to remove weak/export ciphers.
Bind Shell Backdoor (Port 1524)	Immediately kill the process listening on port 1524, audit the system for additional backdoors, and investigate the source of compromise.

High Priority

Finding	Recommended Remediation
VSFTPD 2.3.4 Anonymous Login	Upgrade VSFTPD to the latest stable version. Disable anonymous FTP login. Restrict FTP access by IP or replace with SFTP (SSH-based file transfer).
Telnet Default Credentials	Disable the Telnet service immediately. Replace with SSH using key-based authentication. Change all default credentials on all services.
DVWA Command Injection	Implement strict server-side input validation. Use allowlists for command inputs. Apply Web Application Firewall (WAF) rules. Never pass user input to OS commands.
SMB Anonymous Access	Disable anonymous SMB access. Enforce SMB signing. Upgrade to SMBv3. Restrict SMB to internal network segments only.

Medium Priority

- Update Apache to version 2.4.x or later and PHP to version 8.x
- Restrict phpMyAdmin to authorised IP addresses and enforce strong authentication
- Disable directory browsing on the web server (Options -Indexes in Apache config)
- Disable the HTTP TRACE method (TraceEnable Off in Apache config)
- Remove phpinfo.php and other diagnostic files from the web root

General Hardening Recommendations

- Implement a regular patch management process — schedule monthly security updates
- Apply the principle of least privilege — no service should run as root unnecessarily
- Deploy a firewall and restrict open ports to only those required for business functions
- Implement security headers on all web applications (CSP, HSTS, X-Frame-Options, X-Content-Type-Options)
- Conduct regular VAPT assessments — at minimum annually, or after significant infrastructure changes
- Deploy an Intrusion Detection System (IDS) such as Snort or Suricata to detect exploitation attempts

13. Conclusion

This VAPT exercise demonstrated the end-to-end vulnerability assessment and penetration testing lifecycle against a deliberately vulnerable Metasploitable 2 target system in a controlled lab environment. The assessment successfully demonstrated practical application of industry-standard offensive security tools across all seven attack phases.

The target system was found to be critically vulnerable across virtually every exposed service. Five critical-severity vulnerabilities were confirmed, three services were successfully exploited to gain unauthorised access (Telnet, FTP, and DVWA command injection), and SMB shares were fully enumerated without authentication. Nessus identified a total of 69 vulnerabilities in a 12-minute automated scan.

The exercise highlighted several important security principles that are consistently violated on poorly maintained systems:

- Default credentials must always be changed before deploying any service
- End-of-life operating systems and software receive no security patches and should be replaced immediately
- Unencrypted protocols (Telnet, FTP, HTTP) expose credentials and sensitive data to trivial interception
- Anonymous or unauthenticated access to file-sharing services (FTP, SMB) provides attackers with direct footholds
- Web applications without input validation are vulnerable to command injection and other critical web attacks

The tools used in this assessment — Wireshark, Nmap, Nikto, Nessus, Burp Suite, and native CLI clients — represent a standard toolkit for both offensive security professionals and defensive security engineers. Familiarity with these tools and their output is foundational to any role in cybersecurity.

End of Report